Care Access Navigator

Identity Lifecycle — Joiner / Mover / Leaver (JML) Evidence

Microsoft Entra ID as the source of truth, federated into Keycloak (OIDC) for the Care Access Navigator applications

Prepared by:	Akhila Chennamaneni, GRC / IAM Analyst
Organization:	HealthLine Regional Medical Center — Care Access Navigator (CAN)
Systems:	Microsoft Entra ID (tenant chakhilaraogmail.onmicrosoft.com), enterprise app care-access-navigator-keycloak-broker; Keycloak 26 realm care-access-navigator
Executed:	October 19, 2026 (all times UTC)
Cost:	$0 — Entra ID Free tier; Keycloak local

Purpose

This document proves that HealthLine's access lifecycle works end to end: a new workforce member receives exactly the access their job needs on day one (**Joiner**), a transfer removes old access before granting new access (**Mover**), and a departing employee loses all access the same day (**Leaver**). Each step was executed live and is evidenced three ways: administrator screenshots, read-only system extracts (Microsoft Graph and the Keycloak admin API), and the Entra ID audit log.

How identity flows in Care Access Navigator

Federation model (OIDC)

```
Person signs in --> Microsoft Entra ID ---------------------> Keycloak (realm
  care-access-navigator) --> CAN apps
                  - workforce directory (source of truth)    - auto-creates entra-id.<login>
  account     ehr-simulator
                  - app role on enterprise app                - maps Entra role -> realm role
  (sync FORCE) patient-portal
                    (Clinician, Nurse, Billing, ...)          - password/lockout/MFA rules,
  event logs    billing-app
                  - "assignment required" = only assigned
                                                hr-app
                    people can sign in
```

Requirement	Why	Reference
Access granted by role, least privilege	Staff see only the ePHI their job needs	HIPAA §164.308(a)(4); PCI DSS 7.2
Access changed promptly on transfer	Prevents privilege creep	HIPAA §164.308(a)(4)(ii)(C)
Access removed at termination	Departed staff must not reach ePHI or card data	HIPAA §164.308(a)(3)(ii)(C); PCI DSS 8.2.5
Changes logged and retained	Prove who changed what, when	HIPAA §164.312(b); PCI DSS 10.2

Cast and tickets

Stage	Ticket	Person (display name)	Login (UPN)	Change	Approver
Joiner	REQ-2026-0101	Sathya Hasi — Physician	test.clinician	New account → Clinician	Clinical Ops Manager
Mover	CHG-2026-0201	Tara Jones — RN → Billing Specialist	test.nurse	Nurse → Billing	Billing Manager
Leaver	TERM-2026-0301	Jeevan Smith — Billing Specialist	test.billing	Disable, remove access	Billing Manager + HR

Preparation: Display names were changed from 'Test Nurse' / 'Test Billing' to realistic names before the cycle (audit log 16:08 and 16:10 UTC). Logins and roles were unchanged, so the rename has no security effect.

1. Baseline (before)

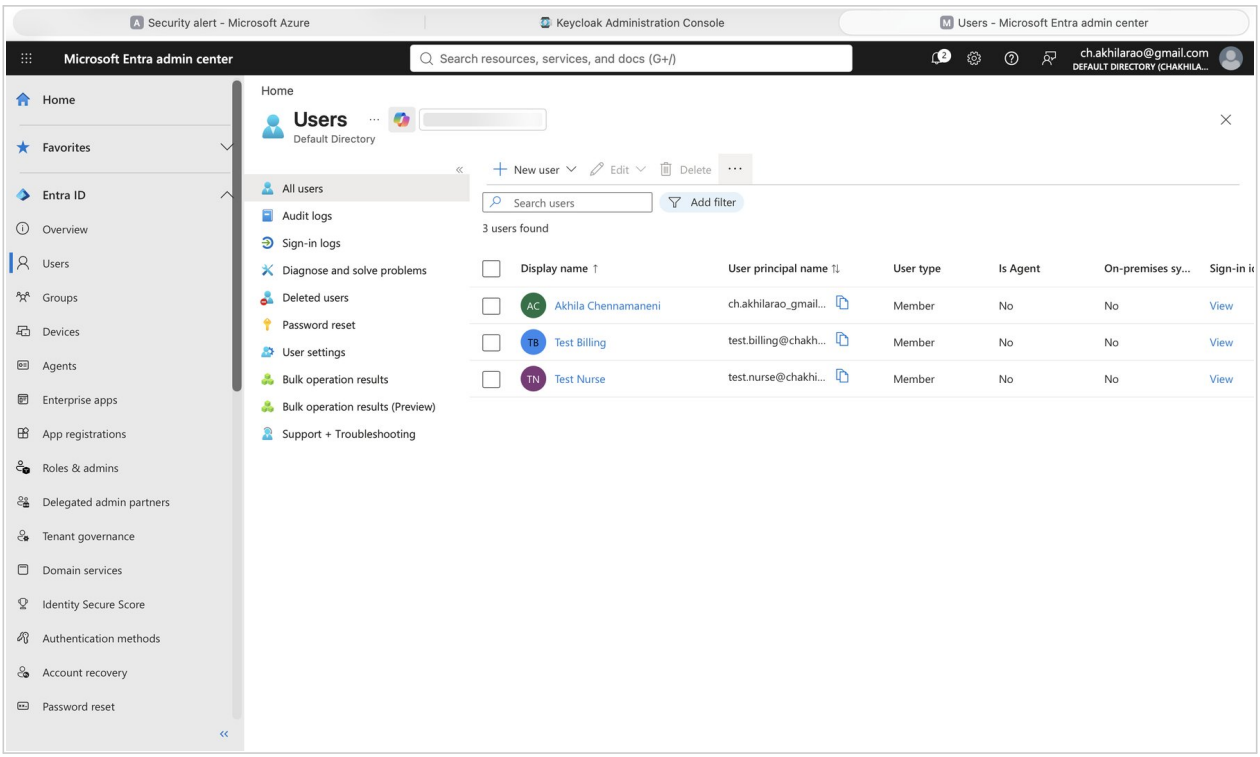


Figure 1. Entra ID users before the cycle: 3 users.

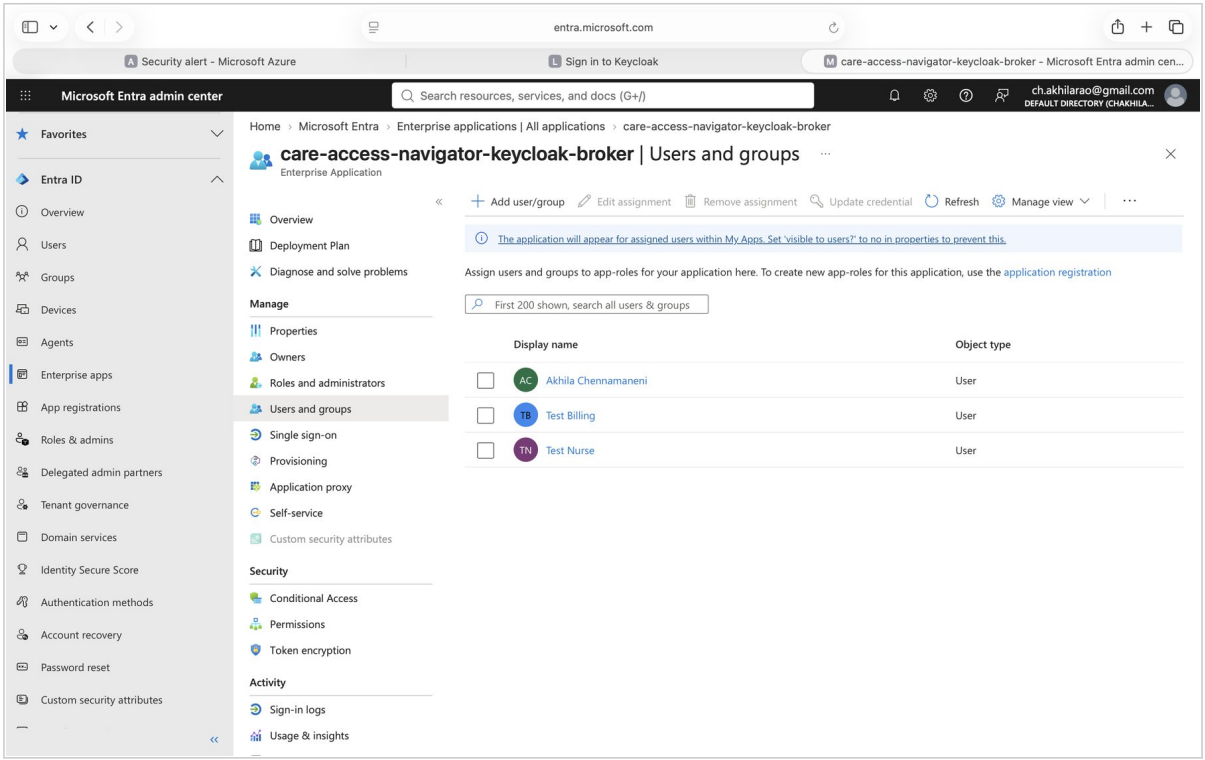


Figure 2. Enterprise app care-access-navigator-keycloak-broker — assigned users before the cycle.

System extract: role assigned to each user (portal list does not show the role column)

```
JML-02b  BEFORE state — app role assignments (Microsoft Graph, read-only)
Application: care-access-navigator-keycloak-broker (enterprise app object id
    7d6c1aa0-df26-46db-ba84-a5efb9df71a0)
Captured:    2026-10-19 15:32:46 UTC by Akhila Chennamaneni (GRC Analyst)

  User                  Type         Role assigned      Assigned on (UTC)
  Akhila Chennamaneni   User         Default Access     2026-09-21 15:52
  Test Billing          User         Billing            2026-10-06 15:28
  Test Nurse            User         Nurse              2026-10-06 15:28

Directory users (job information):
  Akhila Chennamaneni  enabled=True  -                   -
  Test Billing         enabled=True  Billing Specialist   Patient Financial Services
  Test Nurse           enabled=True  Registered Nurse     Med-Surg 4W
```

2. Joiner — Sathya Hasi (REQ-2026-0101)

#	Action	System	Time (UTC)
1	Create user test.clinician, Physician / Internal Medicine, temporary password	Entra ID	16:23
2	Assign app role Clinician on the enterprise app	Entra ID	16:46
3	First sign-in through entra-id; password changed; security info registered	Entra ID	16:53–16:57
4	Keycloak auto-creates entra-id.test.clinician with realm role clinician (REGISTER + LOGIN)	Keycloak	17:10

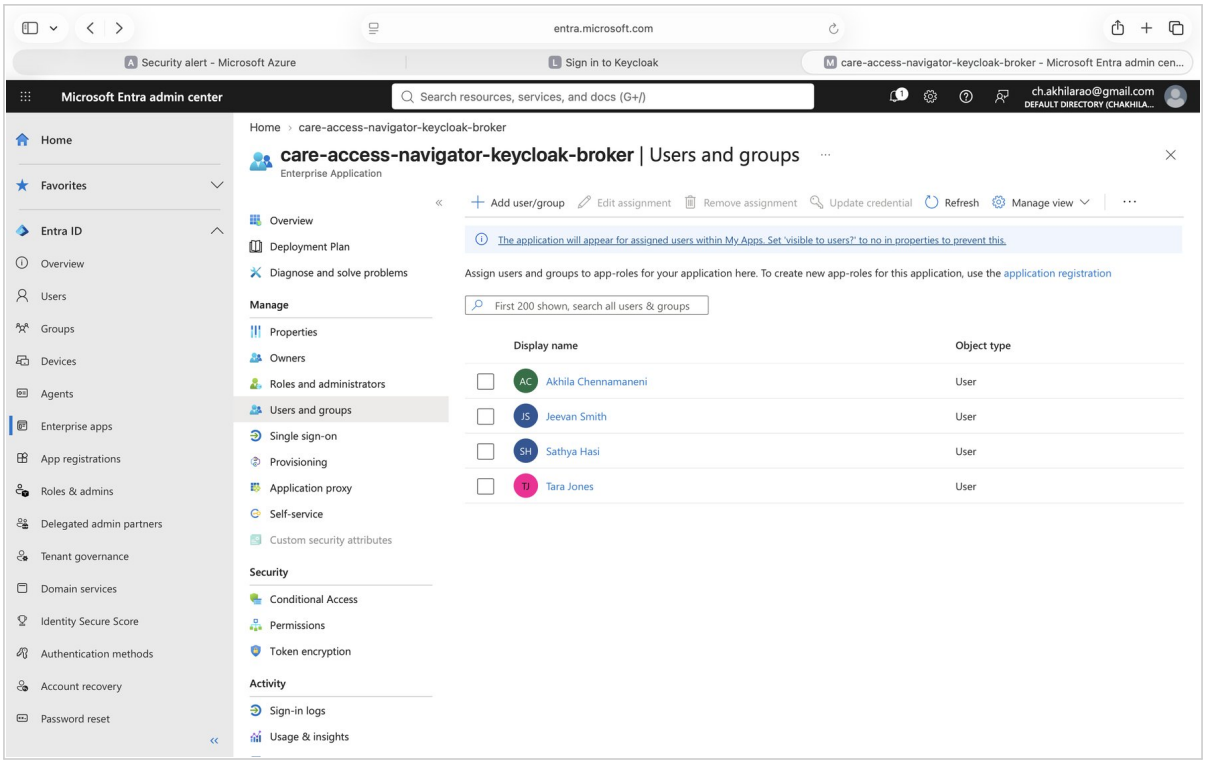


Figure 3. Clinician app role assigned to Sathya Hasi.

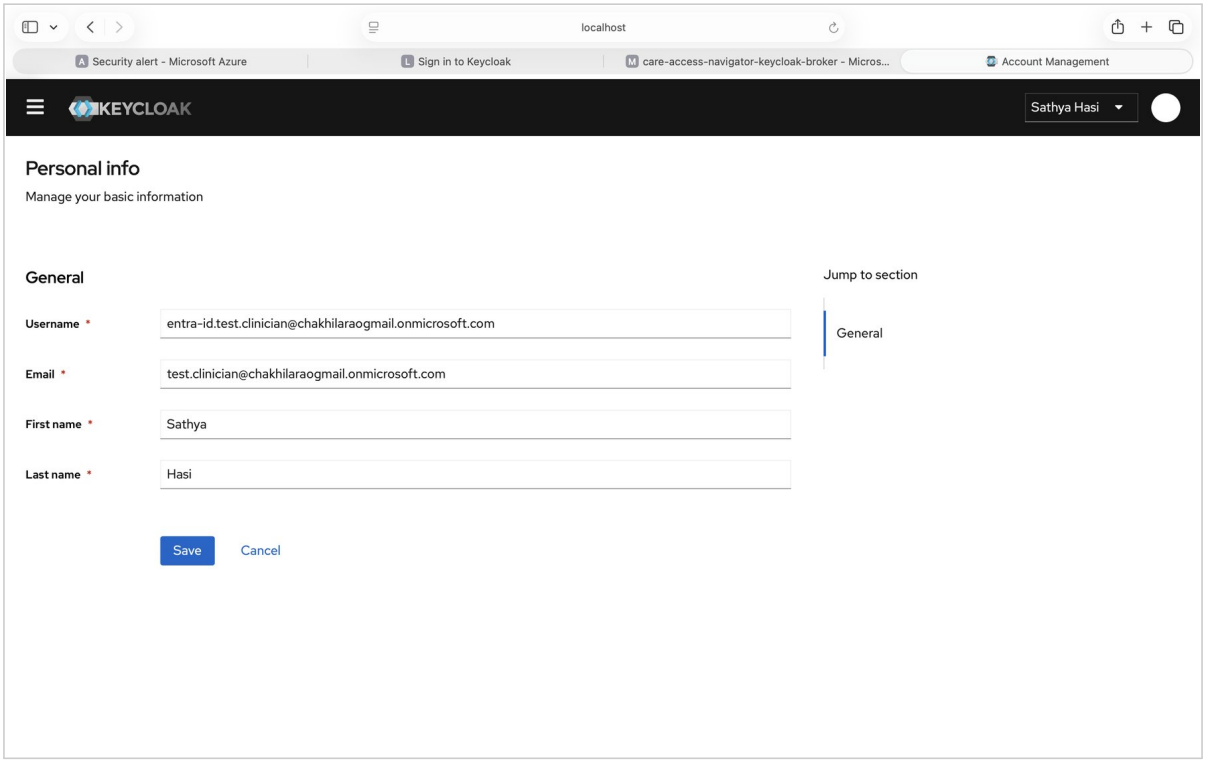


Figure 4. Sathya Hasi's first sign-in lands on the Keycloak account page.

System extract after the joiner (Entra + Keycloak + Keycloak events)

```
JML-05  AFTER JOINER — Sathya Hasi (test.clinician) onboarded as Clinician
Captured: 2026-10-19 17:12:20 UTC (Microsoft Graph + Keycloak admin API, read-only)

Entra ID — app role assignments (care-access-navigator-keycloak-broker):
  Akhila Chennamaneni  -> Default Access  assigned 2026-09-21 15:52 UTC
  Jeevan Smith         -> Billing         assigned 2026-10-06 15:28 UTC
  Sathya Hasi          -> Clinician       assigned 2026-10-19 16:46 UTC
  Tara Jones           -> Nurse           assigned 2026-10-06 15:28 UTC

Keycloak — federated users (realm care-access-navigator) and realm roles:
  entra-id.ch.akhilarao@gmail.com                          Akhila Chennamaneni enabled=True
    roles=(none)           created 2026-10-06 17:06 UTC
  entra-id.test.billing@chakhilaraogmail.onmicrosoft.com   Test Billing   enabled=True
    roles=billing          created 2026-10-06 17:30 UTC
  entra-id.test.clinician@chakhilaraogmail.onmicrosoft.com Sathya Hasi    enabled=True
    roles=clinician        created 2026-10-19 17:10 UTC
  entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com     Test Nurse     enabled=True
    roles=nurse            created 2026-10-06 17:36 UTC

Keycloak — login events for the joiner:
  2026-10-19 17:10:33  LOGIN
    user=entra-id.test.clinician@chakhilaraogmail.onmicrosoft.com idp=entra-id
  2026-10-19 17:10:33  REGISTER
    user=entra-id.test.clinician@chakhilaraogmail.onmicrosoft.com idp=entra-id
  2026-10-19 17:10:33  UPDATE_EMAIL                  user= idp=entra-id
```

Finding: No Keycloak account was created by hand. Keycloak provisioned it just-in-time at first sign-in and gave it only the clinician role, which reaches ehr-simulator and patient-portal but not billing-app or hr-app.

3. Mover — Tara Jones (CHG-2026-0201)

#	Action	System	Time (UTC)
1	Remove app role Nurse (old access removed first)	Entra ID	17:21
2	Assign app role Billing	Entra ID	17:23
3	Revoke sign-in sessions (old tokens invalid)	Entra ID	17:26
4	Job title Registered Nurse → Billing Specialist; dept Med-Surg 4W → Patient Financial Services	Entra ID	17:27
5	Next sign-in: Keycloak re-syncs roles → billing only; name updated to Tara Jones	Keycloak	17:41

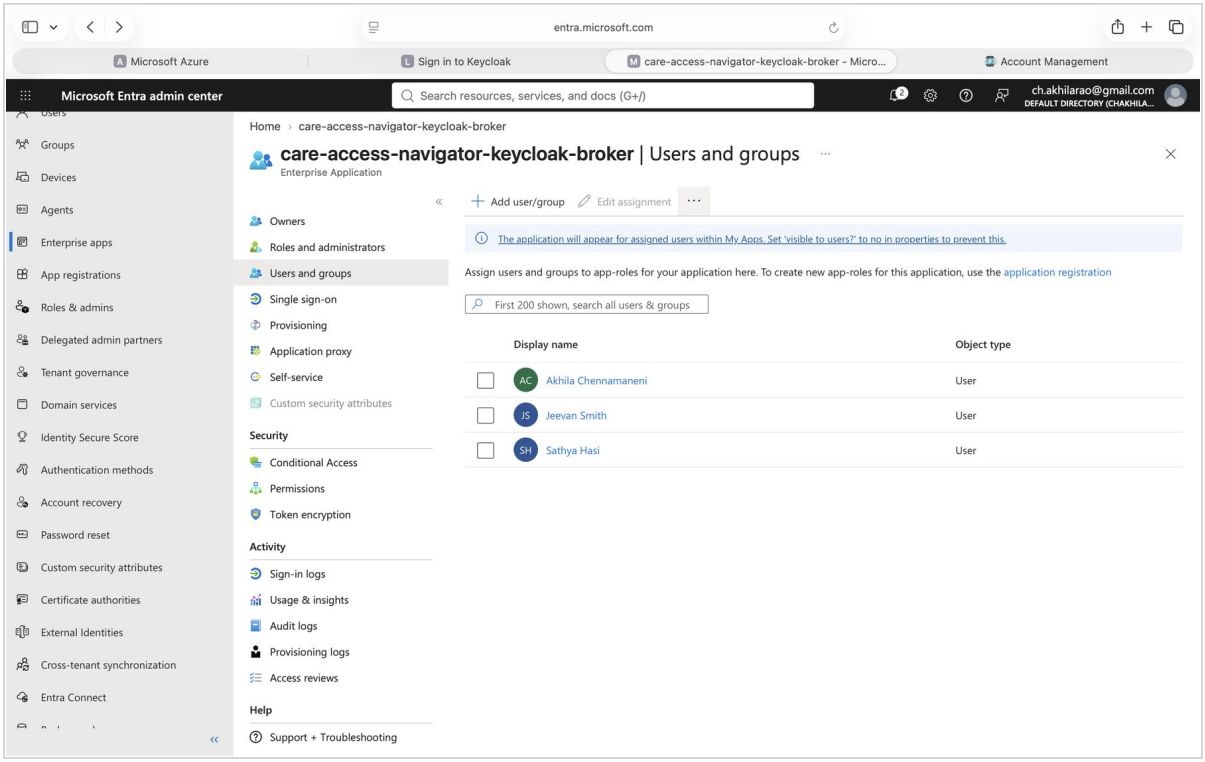


Figure 5. Nurse assignment removed for Tara Jones.

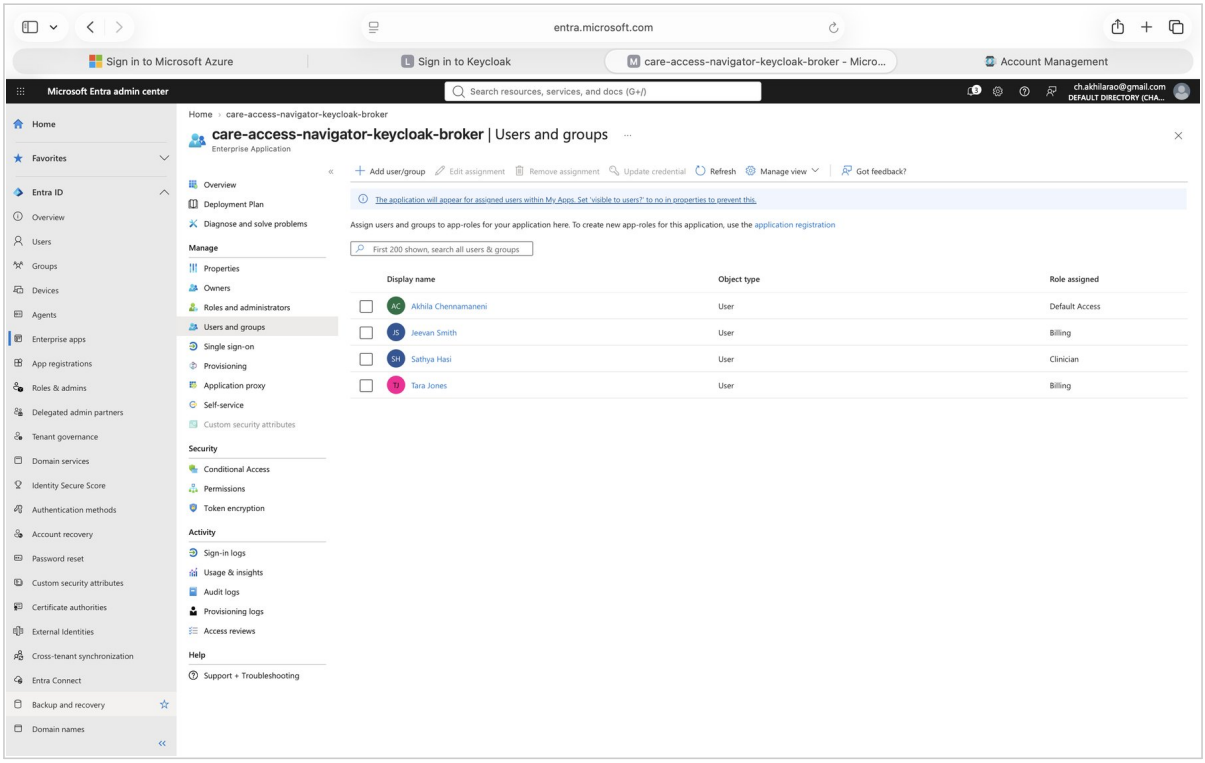


Figure 6. Billing assignment added for Tara Jones.

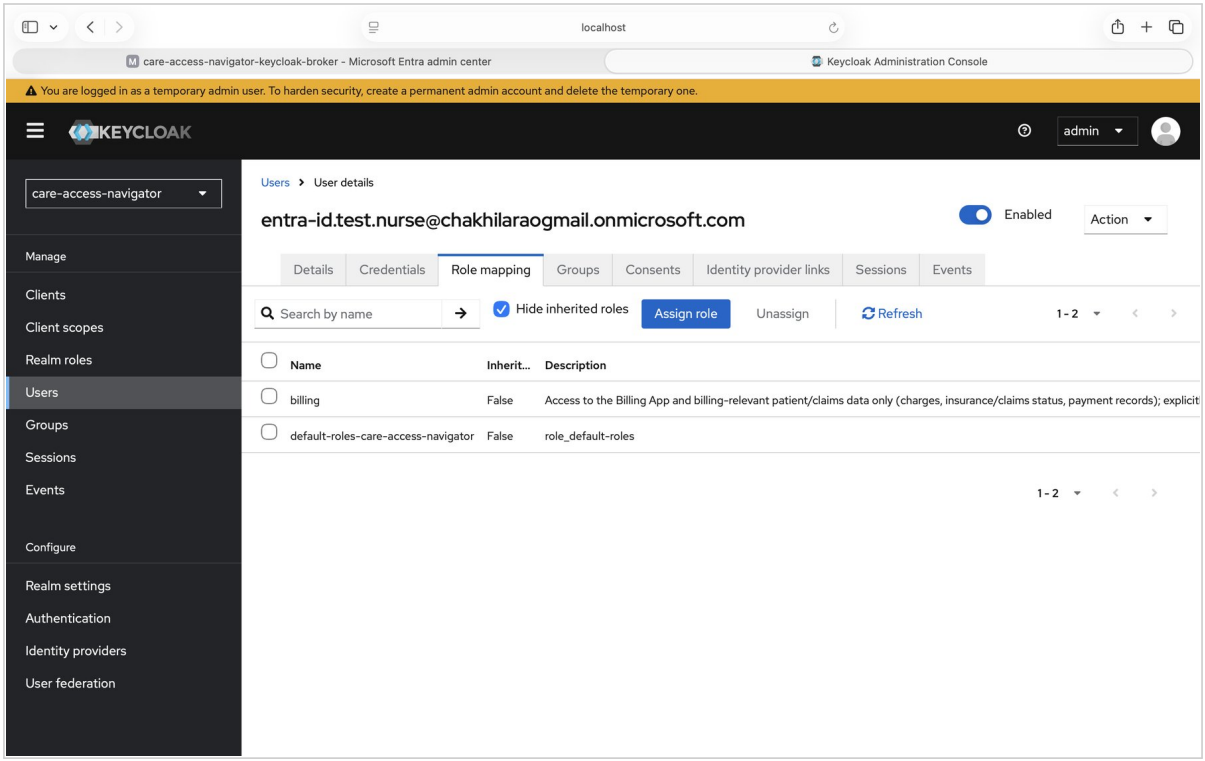


Figure 7. Keycloak role mapping after the move: billing, no nurse.

System extract after the mover

```
JML-09  AFTER MOVER — Tara Jones (test.nurse) moved Nurse -> Billing
Captured: 2026-10-19 17:45:43 UTC (Microsoft Graph + Keycloak admin API, read-only)

Entra ID — app role assignments:
  Akhila Chennamaneni  -> Default Access  assigned 2026-09-21 15:52 UTC
  Jeevan Smith         -> Billing         assigned 2026-10-06 15:28 UTC
  Sathya Hasi          -> Clinician       assigned 2026-10-19 16:46 UTC
  Tara Jones           -> Billing         assigned 2026-10-19 17:23 UTC

Entra ID — Tara Jones profile:
  Tara Jones | Billing Specialist | Patient Financial Services | enabled=True | sessions valid
    from 2026-10-19T17:26:02Z (revocation time)

Keycloak — federated users and realm roles:
  entra-id.ch.akhilarao@gmail.com                          Akhila Chennamaneni  enabled=True
    roles=(none)
  entra-id.test.billing@chakhilaraogmail.onmicrosoft.com   Test Billing         enabled=True
    roles=billing
  entra-id.test.clinician@chakhilaraogmail.onmicrosoft.com Sathya Hasi          enabled=True
    roles=clinician
  entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com     Tara Jones           enabled=True
    roles=billing

Keycloak — recent events for Tara (test.nurse):
  2026-10-19 17:41:26  LOGIN
    user=entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com
```

Finding: Keycloak removed the old nurse role by itself. The identity-provider role mappers use sync mode FORCE, so roles are recalculated from the Entra token at every sign-in. Access is replaced, not accumulated — this is the control that prevents privilege creep.

4. Leaver — Jeevan Smith (TERM-2026-0301)

#	Action	System	Time (UTC)
1	Disable account (block sign-in)	Entra ID	18:13
2	Revoke sign-in sessions	Entra ID	18:15
3	Remove app role Billing from the enterprise app	Entra ID	18:17
4	Disable the Keycloak copy entra-id.test.billing (retained, not deleted); no active sessions	Keycloak	~18:28
5	Verification: sign-in attempt refused — 'Your account has been locked'	Entra ID	after 18:17

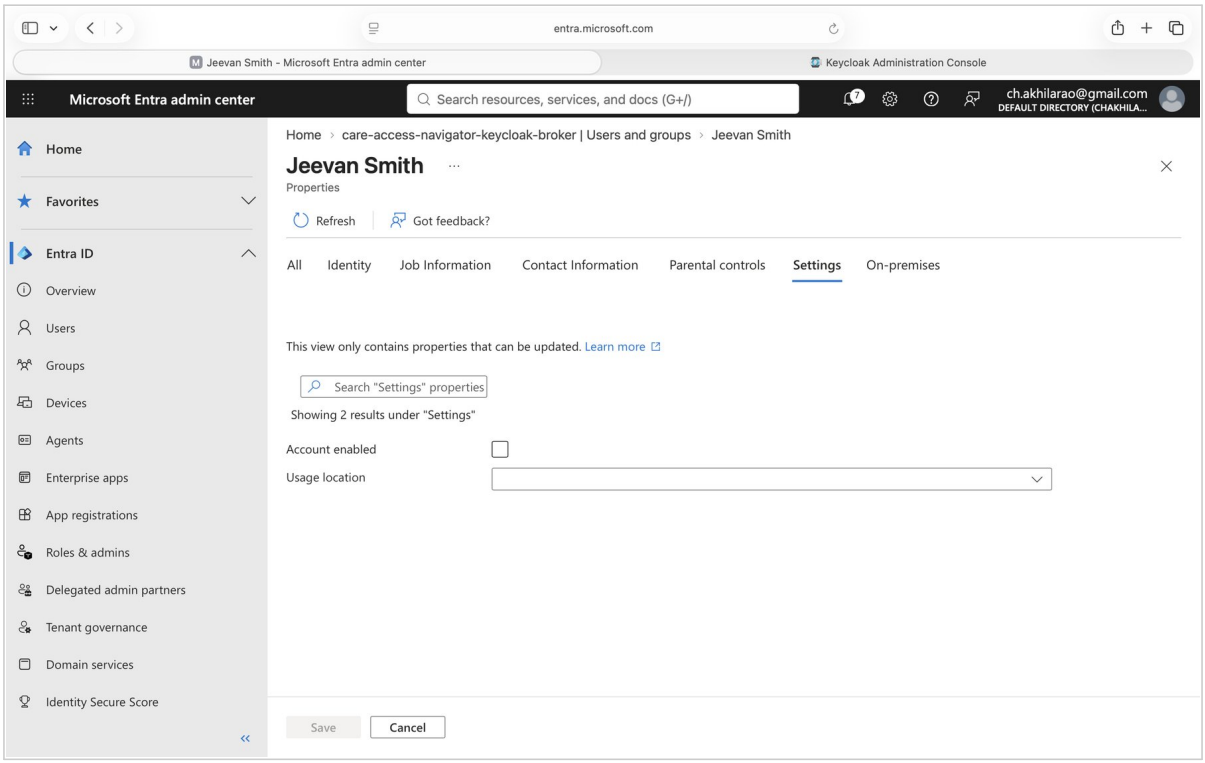


Figure 8. Jeevan Smith's Entra account disabled.

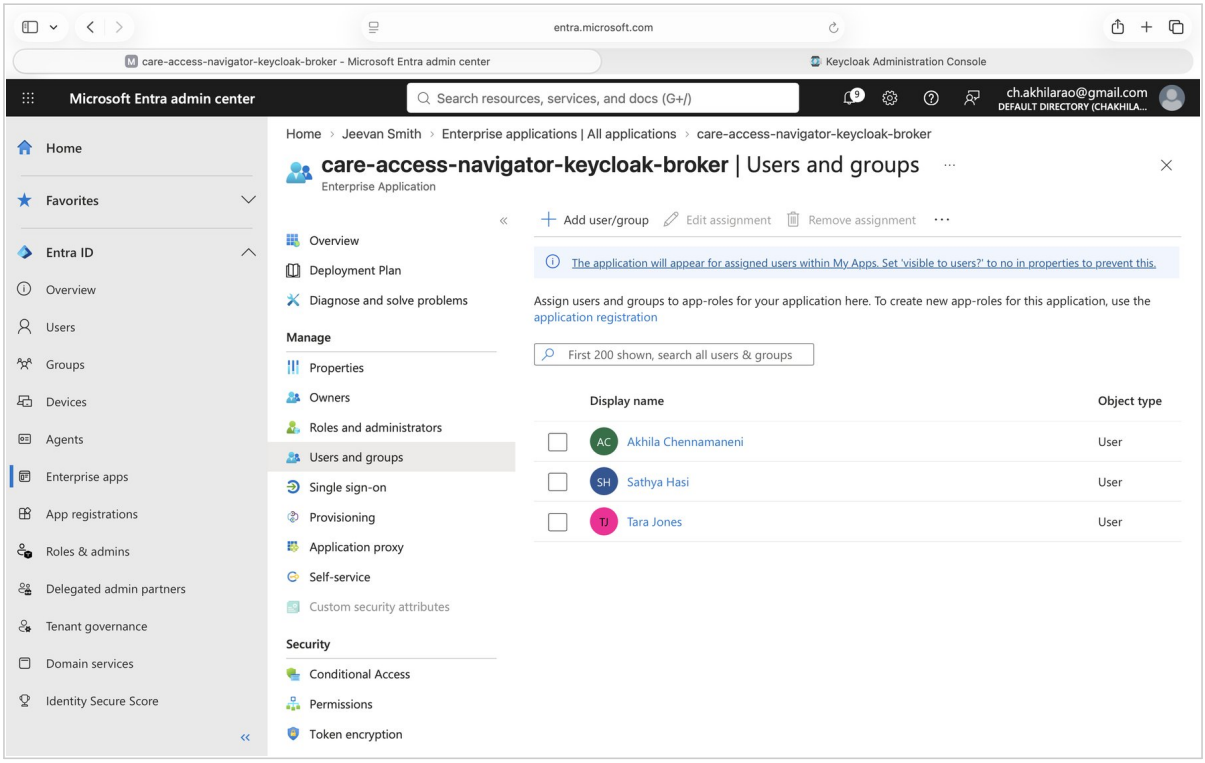


Figure 9. Billing assignment removed — Jeevan no longer listed.

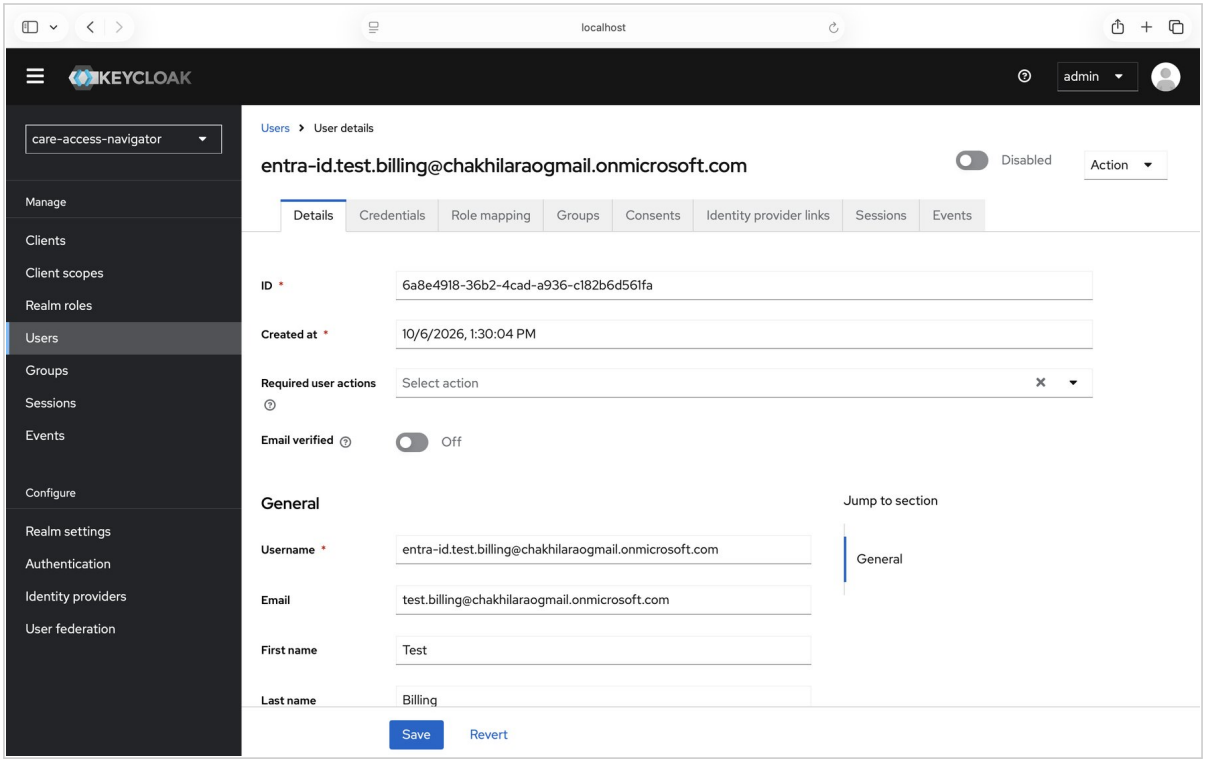


Figure 10. Keycloak copy entra-id.test.billing set to Disabled.

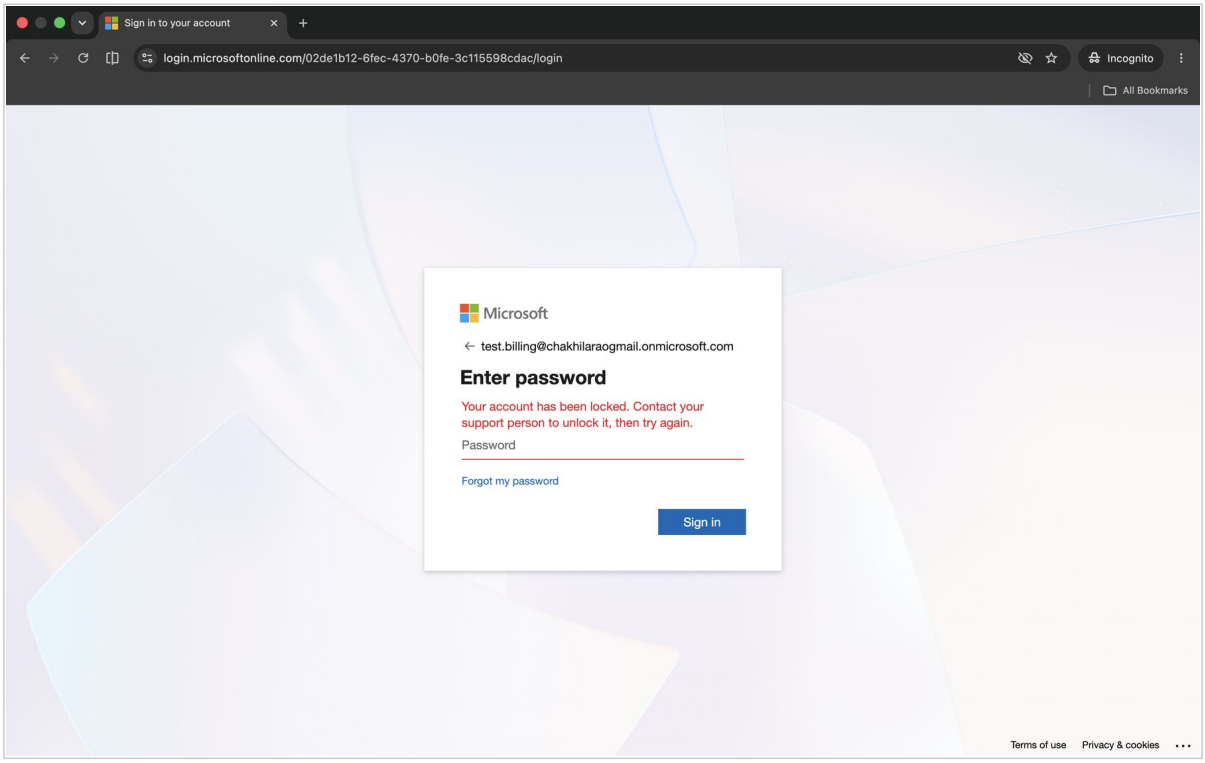


Figure 11. Proof of removal: Microsoft refuses Jeevan's sign-in.

> **Issue found and fixed:** A first attempt left the Keycloak copy enabled (screenshot showed the switch still on). It was caught in verification and corrected; the Keycloak admin API then returned enabled = false. Verification after every change is part of the procedure for this reason.

System extract after the leaver

```
JML-14  AFTER LEAVER — Jeevan Smith (test.billing) offboarded
Captured: 2026-10-19 18:25:42 UTC (Microsoft Graph + Keycloak admin API, read-only)

Entra ID — users:
  Akhila Chennamaneni  ch.akhilarao_gmail.com#EXT#@chakhilaraogmail.o enabled=True  -
                       sessions valid from 2026-08-31T20:37:37Z
  Jeevan Smith         test.billing@chakhilaraogmail.onmicrosoft.com  enabled=False Billing
    Specialist  sessions valid from 2026-10-19T18:15:07Z
  Sathya Hasi          test.clinician@chakhilaraogmail.onmicrosoft.co enabled=True  Physician
               sessions valid from 2026-10-19T16:53:03Z
  Tara Jones           test.nurse@chakhilaraogmail.onmicrosoft.com    enabled=True  Billing
    Specialist  sessions valid from 2026-10-19T17:26:02Z

Entra ID — app role assignments:
  Akhila Chennamaneni  -> Default Access  assigned 2026-09-21 15:52 UTC
  Sathya Hasi          -> Clinician       assigned 2026-10-19 16:46 UTC
  Tara Jones           -> Billing         assigned 2026-10-19 17:23 UTC

Keycloak — federated users:
  entra-id.ch.akhilarao@gmail.com                          Akhila Chennamaneni  enabled=True
    roles=(none)     active sessions=0
  entra-id.test.billing@chakhilaraogmail.onmicrosoft.com   Test Billing         enabled=True
    roles=billing    active sessions=0
  entra-id.test.clinician@chakhilaraogmail.onmicrosoft.com Sathya Hasi          enabled=True
    roles=clinician  active sessions=0
  entra-id.test.nurse@chakhilaraogmail.onmicrosoft.com     Tara Jones           enabled=True
    roles=billing    active sessions=1

Keycloak re-check after the fix: entra-id.test.billing enabled = false
```

5. Independent Evidence — Entra ID Audit Log

The audit log records every administrative change with time, actor and before/after values. It was exported the same day because the Entra ID Free tier keeps audit data for only 7 days. Routine 'Validate user authentication' entries (admin portal sign-ins) are omitted below for readability; the full export is in JML-15-entra-audit-log.txt.

JML-15 (filtered)

```
JML-15  Entra ID audit log — JML cycle 2026-10-19 (Microsoft Graph directoryAudits, read-only)
Captured: 2026-10-19 18:29:54 UTC   (free tier retains 7 days — exported for permanence)

16:08:41  Update user                          test.nurse
      DisplayName: Test Nurse -> Tara Jones
16:10:11  Update user                          test.billing
      DisplayName: Test Billing -> Jeevan Smith
16:23:13  Add user                             test.clinician
      AccountEnabled:  -> true
      Department:  -> Internal Medicine
      DisplayName:  -> Sathya Hasi
      JobTitle:  -> Physician
16:46:23  Add app role assignment grant to use app: test.clinician@chakhi
      AppRole.Value:  -> Clinician
16:53:03  Change user password                 test.clinician
16:56:55  Update user                          test.clinician
16:56:55  Update user                          test.clinician
16:57:15  Update user                          test.clinician
16:57:15  User registered security info        Sathya Hasi
16:57:16  User registered security info        Sathya Hasi
16:57:25  Update user                          test.clinician
16:57:25  User registered security info        Sathya Hasi
17:21:00  Remove app role assignment from user app: test.nurse@chakhilara
      AppRole.Value:  ->
17:23:28  Add app role assignment grant to use app: test.nurse@chakhilara
      AppRole.Value:  -> Billing
17:26:02  Update user                          test.nurse
17:27:19  Update user                          test.nurse
      Department: Med-Surg 4W -> Patient Financial Services
      JobTitle: Registered Nurse -> Billing Specialist
18:13:55  Disable account                      test.billing
      AccountEnabled: true -> false
18:13:55  Update user                          test.billing
      AccountEnabled: true -> false
18:15:07  Update user                          test.billing
18:17:05  Remove app role assignment from user app: test.billing@chakhila
      AppRole.Value:  ->
```

6. JML Change Log

Ticket	Type	Person	Before	After	Entra time	Keycloak time
REQ-2026-0101	Joiner	Sathya Hasi	No account	Clinician	16:23 / 16:46	17:10
CHG-2026-0201	Mover	Tara Jones	Nurse	Billing (nurse removed)	17:21 / 17:23 / 17:26	17:41
TERM-2026-0301	Leaver	Jeevan Smith	Billing, enabled	Disabled, no role	18:13 / 18:15 / 18:17	~18:28

Machine-readable copy: JML-LOG.csv. All files are fingerprinted in EVIDENCE-INDEX-SHA256.txt.

7. Key Findings and Lessons Learned

#	Observation	Implication / recommendation
1	Joiner provisioning is automatic: assigning one Entra app role was enough to create a correctly scoped Keycloak account at first sign-in.	Single point of control (Entra). No duplicate accounts to maintain.
2	Mover: Keycloak replaced nurse with billing on the next sign-in (sync FORCE).	Privilege creep prevented by design. Revoking Entra sessions forces that next sign-in.
3	Leaver: Entra blocks sign-in immediately, but Keycloak is not notified — its copy stays enabled until an admin disables it.	**Known limitation.** Keep the manual Keycloak step in the procedure; future improvement: SCIM/automated deprovisioning or a scheduled reconciliation script.
4	An existing Keycloak session would survive Entra revocation until it expires (30-min idle).	Always sign out Keycloak sessions for leavers; consider shorter session lifetimes for privileged roles.
5	Accounts are disabled, not deleted.	Preserves audit trail (HIPAA 6-year documentation retention).
6	Assigning Entra groups to the app requires a paid licence (P1/P2).	Users are assigned individually on the Free tier; group-based assignment is the scalable option if licensed.
7	Keycloak shows the old name 'Test Billing' for the leaver.	Expected: names re-sync only at sign-in, and a leaver never signs in again.
8	Entra Free keeps audit logs 7 days.	Export audit logs promptly or stream them to a log store (Compliance finding F-03).

Conclusion

All three lifecycle events completed successfully and were independently verified in Entra ID, Keycloak and the audit log. The design gives least-privilege access on day one, replaces rather than accumulates access on transfer, and removes access on termination — with one documented manual control (disabling the Keycloak copy) until automated deprovisioning is introduced.